



## Article

# A Secure Approach Out-of-Band for e-Bank with Visual Two-Factor Authorization Protocol

Laerte Peotta de Melo <sup>1</sup>, Dino Macedo Amaral <sup>1</sup>, Robson de Oliveira Albuquerque <sup>1,2</sup>,  
Rafael Timóteo de Sousa Júnior <sup>1</sup>, Ana Lucila Sandoval Orozco <sup>1,2</sup> and Luis Javier García Villalba <sup>2,\*</sup>

<sup>1</sup> Department of Electrical Engineering, University of Brasília, Federal District, Brasília 70910-900, Brazil; peotta@bb.com.br (L.P.d.M.); dinoamaral@bb.com.br (D.M.A.); robson@redes.unb.br (R.d.O.A.); desousa@unb.br (R.T.d.S.J.); asandoval@fdi.ucm.es (A.L.S.O.)

<sup>2</sup> Group of Analysis, Security and Systems (GASS), Department of Software Engineering and Artificial Intelligence (DISIA), Faculty of Computer Science and Engineering, Office 431, Universidad Complutense de Madrid (UCM), Calle Profesor José García Santesmases, 9, Ciudad Universitaria, 28040 Madrid, Spain

\* Correspondence: javiergv@fdi.ucm.es

**Abstract:** The article presents an innovative approach for secure authentication in internet banking transactions, utilizing an Out-of-Band visual two-factor authorization protocol. With the increasing rise of cyber attacks and fraud, new security models are needed that ensure the integrity, authenticity, and confidentiality of financial transactions. The identified gap lies in the inability of traditional authentication methods, such as TANs and tokens, to provide security in untrusted terminals. The proposed solution is the Dynamic Authorization Protocol (DAP), which uses mobile devices to validate transactions through visual codes, such as QR codes. Each transaction is assigned a unique associated code, and the challenge must be responded to within 120 s. The customer initiates the transaction on a computer and independently validates it on their mobile device using an out-of-band channel to prevent attacks such as phishing and man-in-the-middle. The methodology involves implementing a prototype in Java ME for Android devices and a Java application server, creating a practical, low-computational-cost system, accessible for use across different operating systems and devices. The protocol was tested in real-world scenarios, focusing on ensuring transaction integrity and authenticity. The results show a successful implementation at Banco do Brasil, with 3.6 million active users, demonstrating the efficiency of the model over 12 years of use without significant vulnerabilities. The DAP protocol provides a robust and effective solution for securing banking transactions and can be extended to other authentication environments, such as payment terminals and point of sale devices.

**Keywords:** online banking; cyber fraud; two-factor authentication; authorization



**Citation:** de Melo, L.P.; Macedo Amaral, D.; de Oliveira Albuquerque, R.; de Sousa Júnior, R.T.; Sandoval Orozco, A.L.; García Villalba, L.J. A Secure Approach Out-of-Band for e-Bank with Visual Two-Factor Authorization Protocol. *Cryptography* **2024**, *8*, 51. <https://doi.org/10.3390/cryptography8040051>

Academic Editor: Josef Pieprzyk

Received: 17 September 2024

Revised: 31 October 2024

Accepted: 1 November 2024

Published: 11 November 2024



**Copyright:** © 2024 by the authors. Licensee MDPI, Basel, Switzerland. This article is an open access article distributed under the terms and conditions of the Creative Commons Attribution (CC BY) license (<https://creativecommons.org/licenses/by/4.0/>).

## 1. Introduction

Emerging in the 1980s, Internet banking models have evolved alongside the Internet. Various financial institutions in Europe and the United States developed home banking experiments, initially using fax machines and telephones. These innovations expanded e-commerce and increased the usage of the Internet beyond specific groups. The convenience of electronic services contributed to their widespread adoption, though security remains a critical concern. Ensuring constant availability, as well as the integrity and confidentiality of the accessed and stored information, is essential to maintain user privacy and trust [1].

Internet banking systems offer a convenient way to adapt traditional banking services to a digital infrastructure. These systems bring banking directly to the customer, saving time and enabling new business models and opportunities. Despite the growth in usage, security models have not kept up with advances in access technology [2]. Requiring access from known or pre-registered devices contradicts the concepts of mobility and

usability. Moreover, relying on challenge-response mechanisms can expose the system to vulnerabilities, allowing adversaries to impersonate legitimate users by responding to all challenges, the attack model will be detailed in the Section 4.

The increasing sophistication of attack techniques has challenged researchers and financial institutions to develop security solutions that offer both mobility and protection. These solutions should not be limited to proprietary systems or specific browser versions, as such restrictions can hinder secure access and management. Mobile devices represent a promising short-term solution for Internet banking access, providing both flexibility and security [3].

To meet new security and mobility challenges, a model can be developed using customer authentication and authorization via a mobile phone in an out-of-band manner. This approach employs simple mathematical processing and a camera to capture visual codes (QR codes).

The “What You See Is What You Sign” principle allows customers to verify transaction details on an untrusted computer screen by using their trusted mobile device to read and decrypt authorization codes. When using separate channels to carry out a transaction, the adversary will have to compromise both channels for it to be successful and execute the same transaction, for this reason the customer initiates the transaction on a computer and validates it on a mobile terminal, segmenting the authorizing channel out of band. This research proposes a dynamic authorization protocol that enhances Internet banking security through two-factor visual authentication. A proof-of-concept was implemented in Java ME for Android devices, featuring a Java application server and a mobile app.

The Dynamic Authorization Protocol (DAP) enhances security in financial transactions by providing authentication and authorization through a separate channel (out-of-band) and visual codes, such as QR codes. This approach protects against man-in-the-middle and phishing attacks by allowing users to verify the authenticity and integrity of each transaction on their mobile devices. Designed for mobile devices, it ensures convenient access to banking information in various operating systems and software. It also reduces vulnerability to attacks, as the protocol is independent of specific hardware or software, increasing robustness and flexibility in implementation. Optimize usability by requiring minimal user interaction, making the authentication process faster and more efficient [4]. This reduction in friction improves the user experience compared to more complex authentication systems [5].

This protocol is designed to address known security issues by ensuring the integrity, authenticity, and confidentiality of banking transactions. This becomes crucial to prevent fraud and cyberattacks, which are increasingly frequent. One of the protocol’s most significant innovations is out-of-band authentication (OOB).

The out-of-band (OOB) approach for authentication and authorization of internet banking transactions enhances security in several ways:

**Channel Separation:** It allows authentication to occur over a separate channel from the main channel used to perform the transaction. For example, while the user interacts with the bank’s website on a computer, transaction authorization can take place on a mobile device via a QR code or another visual method.

**Visual verification: what you see is what you sign:** Using visual codes, such as QR codes, users can verify the transaction details they are authorizing. This minimizes the risk of fraud, where malicious software could alter transaction details without the user noticing. Users can verify the authenticity of the transaction on a trusted device (such as their smartphone) using cryptographic functions that ensure the integrity of the message.

**Reduction of attack vectors: immunity to man-in-the-middle attacks:** By separating the communication for transaction authorization from the communication for transaction execution (e.g., the bank’s website), the system becomes less susceptible to man-in-the-middle attacks, where an attacker intercepts and manipulates the communication between the user and the bank. Even in the case of a phishing attack, simply obtaining the user’s credentials would not be sufficient to confirm a transaction.

**Authentication without dependence on connected networks (off-line):** Authentication is enabled even when there is no network connectivity, as visual codes can be read in offline

mode. This improves the resilience to attacks, particularly in situations where the network is unstable or compromised, and also improves the user experience in mobile systems that experience connectivity fluctuations.

Protection against social engineering, reducing the risk of data breach: The use of a separate channel and the secure storage of authentication keys make it more difficult for the user to inadvertently disclose their credentials, even when targeted by social engineering tactics. Since authentication codes are not entered into the web interface, the risk of exposure during such attacks is negligible. Social engineering is widely exploited by attackers, as the focus of attacks tends to shift towards exploiting the human factor as new security layers are implemented. However, the protocol described in this work mitigates this vulnerability by isolating the impact of social engineering. This is achieved because the secret required for the user to validate a transaction is not known to the user themselves. Thus, in such an attack, the user would be unable to provide critical data, as this information is generated and used exclusively by the system without exposure to the legitimate user.

Transaction confirmation feature with one-time transaction authentication: Each transaction is authorized with a unique and specific code, known as a transaction authorization number (TAN), ensuring that even if an attacker obtains a user's login credentials, they cannot execute transactions without additional authorization.

Flexibility, accessibility, and independence from hardware and software: The implementation is not dependent on specific hardware or software, meaning it can be accessed from different devices and operating systems, increasing the accessibility of the solution and reducing the likelihood of security vulnerabilities associated with specific platforms.

The out-of-band approach, by proposing the separation of authentication and authorization channels and using visual elements for verification while operating independently of network connections, provides a robust layer of security for Internet banking transactions. This strategy, coupled with protection against various forms of attacks, improves the security and user confidence in digital banking services.

This feature allows users to initiate a transaction on one channel and complete it on a separate secure channel without requiring connectivity with the transaction interface. This approach reduces vulnerability to attacks, such as social engineering, by securely storing the authentication key, preventing accidental exposure. In addition, the protocol is designed to require low computational power and minimal user interaction, facilitating its implementation in real-world environments and making it accessible to a broad spectrum of users. Its compatibility and accessibility are also key advantages, as the protocol is not dependent on specific hardware or software. This flexibility allows users to access their information across different operating systems and devices, further enhancing accessibility. In addition, it demonstrates resilience to emerging threats by considering the challenges associated with rapid developments and new access technologies. This feature addresses the need for security in a constantly evolving environment, making the system more robust against new technological challenges. Although developed primarily for banking transaction authentication and authorization, the protocol can be extended to other authentication methods, such as purchases at point-of-sale terminals, further increasing its applicability.

The main contributions of the proposed Visual Two-Factor Authorization Protocol (DAP) presented in the article include:

1. **Secure and Flexible Authentication:** The protocol allows users to authenticate and authorize banking transactions using a mobile device, providing a method that does not require direct online communication, as the entire transaction verification process is offline. This increases security by reducing the risk of man-in-the-middle attacks, phishing, and even device compromise.
2. **Use of Visual Codes:** The introduction of visual codes, such as QR codes, for transaction verification offers a promising way for users to view and confirm the authenticity of transactions before authorizing them. This ensures that the user can verify the integrity of the entire operation.

3. **Reduction of Attack Vulnerability:** DAP was designed to address known security issues in banking systems without relying on specific hardware or software. This results in greater robustness and flexibility in implementation, making it applicable to a variety of systems.
4. **Ease of Use:** The protocol requires minimal user interaction, optimizing the authentication process. This reduces friction, which often impacts the user experience in more complex authentication systems.
5. **Two-Factor Authentication Model:** By incorporating a second factor, the visual approach on the mobile device complements the initial authentication, making the system more secure. This reduces the likelihood of an adversary successfully impersonating a legitimate user.
6. **Security through an Out-of-Band Channel:** With authorization occurring outside the channel used for the transaction request, the protocol ensures that even if the online communication channel is compromised, the authorization remains secure.

These contributions demonstrate an improvement over traditional authentication models that rely solely on passwords or known devices, addressing attack vectors and reducing vulnerabilities and challenges in online banking transaction security. The implementation of this protocol in banking services presents an innovative and secure solution for transaction authentication and authorization, ensuring protection and convenience in an environment increasingly vulnerable to cyber threats and fraud. This approach provides users with a secure experience without compromising ease of use.

This paper is organized as follows: In Section 1 introduces the topic, providing an overview of authentication methodologies and the importance of security in transaction authorization processes. Section 2 discusses related works and the historical context, addressing the vulnerability of transactions in untrusted terminals and the shortcomings of traditional authentication methods, such as Transaction Authentication Numbers (TANs). Section 3 focuses on the proposed methodology for online banking systems, detailing a model that integrates cryptographic protocols to ensure the integrity, authenticity, and confidentiality of the messages exchanged between the customer and the financial institution. Following that, Section 4 analyzes the Dynamic Authorization Protocol (DAP), detailing its innovations and comparing it to previous security approaches. Section 5 explores the proposal for a protocol that utilizes two-factor authentication, emphasizing the complexity and challenges faced by banking systems, especially regarding protection against adversaries. Finally, Section 6 concludes the discussion by presenting the difficulties related to the human factor in transaction security, as well as considering the impact of new cyber threats and the importance of continuous innovations to maintain security in a rapidly evolving financial environment.

## 2. Related Works and Background

**Formalization Protocol and Privacy Concerns:** The DAP protocol was fully formalized, with lemmas that confirm its reliability with respect to smartphones, agents, and server operations [6]. However, privacy concerns arise as transactions are transmitted in clear text over the network. Despite these limitations, the protocol achieves many of its goals, especially with the use of the Transaction Authorization Number (TAN), which uniquely identifies transactions and ensures authenticity [7].

**Multifactor Authentication Techniques and QR Code Solutions:** This survey [8] identified the main multifactor authentication techniques to mitigate the risk of fraudulent transactions. In their analysis, the authors investigated 92 articles, with the most relevant addressing authentication problems. QR code is considered an innovative solution for multifactor authentication, as it increases security by 46%, ensuring that the user is legitimate. By generating a unique code for each transaction and with a short challenge-response time, an even stronger layer of security is added to these transactions, using advanced technologies and algorithms to predict and identify transaction risks, discouraging fraudster attacks. In this way, customers of these banking systems have the power to verify transactions in

real-time, and the guarantee of message integrity and unique authorization adds significant value to transaction security. As a result, they have proved to be interesting and promising. However, an issue encountered is how to implement these solutions, which is identified as one of the main challenges highlighted in the survey. In the work [9], describes a mobile banking system that uses QR codes and biometric authentication to ensure transaction security. Users validate their transactions directly on their mobile devices through QR codes. Biometric authentication, such as fingerprint or facial recognition, provides an additional layer of protection, making the system more resilient to fraud and cyberattacks. Although the article does not detail the key exchange process or the encryption algorithm used, it is clear that these techniques are crucial for the system's security. The articles [10,11], propose the use of QR codes as a solution for secure authentication in online banking systems. The methods share common features, such as allowing users to validate their transactions using a QR code on their mobile devices, highlighting the advantages of this approach in protecting transactions against common cyberattacks, such as phishing and man-in-the-middle. The authors do not provide specific details about the encryption used or the key exchange process. Traditional authentication approaches, such as those based on knowledge or biometrics, exhibit vulnerabilities that increase the demand for more robust authentication methods, such as multifactor authentication (2FA and MFA). Specifically, SMS-based multifactor authentication has significant shortcomings due to limitations in cellular network security and the SS7 protocol, leading to the recognition that it is not suitable for high-value financial accounts.

**Previous Methods TANs and Security Tokens:** Previous methods such as TANs and security tokens fail to ensure that transaction content is not manipulated; the proposed approach is motivated by the need for user validation. The proposed methodology is the QR-TAN technique, which utilizes QR codes to securely authenticate transactions, even on untrusted devices. The QR-TAN technique allows users to validate transactions on mobile devices, achieving a high level of security without the need for additional software on the terminal [12]. In contrast, previous methods, such as TANs and security tokens, have shown vulnerabilities, particularly in untrusted terminals, which undermine the assurance against manipulation of transaction content. Techniques like QR-TAN utilize QR codes to enable users to authenticate transactions on mobile devices, even in insecure environments, without the need for additional software on the terminals.

**Challenges of SMS-Based Multifactor Authentication:** Challenges of SMS-based multifactor authentication, including cellular security deficiencies and vulnerabilities in the SS7 protocol. Past methods, such as exclusive use of passwords, have proven inadequate due to the rise of cyber threats. The motivation for this approach is clear, given the need for additional security. The proposed methodology involves a critical analysis of SMS authentication methods and their vulnerabilities, without presenting a new solution [13]. The focus is on evaluating the security of SMS as an authentication factor, highlighting that, while it is more secure than passwords alone, it is not suitable for accounts with high financial value.

**Authentication Methods and Cyber Threats:** The growing popularity of online banking and the authentication methods used to protect customer accounts against cyber attacks. Past methods include knowledge-based authentication (KBA), biometric authentication (BBA), and possession-based authentication (PBA), which present vulnerabilities such as phishing and social engineering attacks. The approach is well motivated by the need for enhanced security. The proposed research methodology is a systematic review of the literature (SLR) that analyzes authentication methods and cyber threats from 2013 to 2023. The performance of the methods discussed suggests that the adoption of BBA, 2FA [14], and MFA can significantly improve the security of online banking systems, although new cybersecurity challenges may arise [15]. The increasing complexity and sophistication of cyber threats challenges organizations in protecting their critical infrastructures [16]. Previous methods focus on internal contexts without adequately considering adversaries, resulting in a lack of situational awareness regarding the threat landscape. The proposed approach is motivated by the need to integrate threat intelligence into risk management [17]. The research methodology involves the

continuous integration of threat intelligence into the EBIOS risk management framework, in order to enhance risk assessment and prioritization. The performance of the proposed method is applied within a national telecommunications organization, demonstrating improvements in risk management by considering dynamic threat information. The evolution of cyber threats and the need for adaptations in authentication methods underscore the complexity of the modern financial landscape and the importance of ongoing innovations to ensure user security. In the context of the Internet of Things (IoT), the importance of the onboarding process in establishing trust relationships is emphasized, with recommendations for using installation protocols that consider both trusted and untrusted installers to mitigate security risks. Therefore, while the DAP protocol presents a practical innovation in visual and mobile authentication, other methodologies highlight shortcomings in previous systems and seek to improve the security of electronic transactions.

The article Study and Analysis of FIDO2 Passwordless Web Authentication [18] discusses the implementation and advantages of FIDO2, a passwordless authentication standard that uses cryptographic keys to securely authenticate users on the web. The study examines how FIDO2 improves security compared to traditional passwords and two-factor authentication (2FA), highlighting known vulnerabilities in those systems. It also presents various applications of FIDO2, particularly in areas such as online payments, banking, and other systems that require strong authentication. The primary issue with using FIDO2 is its reliance on specific hardware for authentication, such as physical security keys or biometric-enabled devices. This dependency can pose barriers to widespread adoption, as not all users or organizations have easy access to these devices. Another challenge is interoperability, since FIDO2 requires complete support for WebAuthn and CTAP2 standards across browsers, devices, and services, which may vary between platforms. Furthermore, there is the risk of losing or having the authentication hardware stolen, which could complicate recovery processes and system access. For banks, where security is critical, these technical and logistical issues can hinder the adoption and implementation of the solution, potentially increasing the cost of deployment.

Comparative analysis between the DAP protocol and other security approaches for electronic transactions reveals significant differences and similarities in authentication methods and financial operations protection. The DAP is distinguished by its use of mobile authentication, where each transaction is authorized via a visual code generated by the banking system. This ensures that messages are unique and protected against modifications through cryptographic techniques that guarantee the integrity and authenticity of transactions. This approach is designed to be practical and easily implementable, compatible with common devices and existing banking systems.

### 3. Methodology

This Section presents the model for secure online banking systems, consists of a set of cryptographic protocols that seeks to guarantee integrity, authenticity and confidentiality of messages exchanged between customer's machine and financial institution's website.

This proposal is considered practical, as they can be implemented requiring low computational power and minimal customer interaction or knowledge-based obscurity. Despite getting a solution based on cryptographic primitives and protocols may be simple, is necessary to consider many factors, like low interaction with the client, addition to limited bandwidth and computing power. These constraints impose clear limits in what kind of primitives and protocols should be used, a convenient solution must be either cryptographically strong and practically feasible for the customer.

In this model, each message exchanged in the Internet banking channel is considered unique and must be authorized by the legitimate customer, instead of trusting on data received during an authenticated session (and thus performing transactions in a common context session). For each transaction, customers are challenged to prove their identity before authorizing their transactions, moreover, each proof of identity provided by the customer must be strictly associated with a particular transaction, protecting against

the attacks described in Section 4.1. This approach is possible through a protocol that focus in authorizing transactions, an identification protocol altered, if the customer is the legitimate owner of a secret key exchanged with the bank, responding to the challenges strictly associated with specific operations. The customer is also capable of verifying the authenticity of the challenges sent by the banking system through a message authentication code and an authentication key previously exchanged with the bank.

Even if the adversary is capable to perform operations through the techniques described in Sections 4.2 and 4.3, it cannot authorize it because the adversary is not capable of take any action on smartphone [19]. The adversary is then forced to use social engineering techniques [20], trying to deceive the customer, in order to authorize an illegitimate message, even after verifying the authenticity of the challenges and transaction data. This approach prevents all common attacks carried out by adversaries and described in Section 5, since the adversary is not able to authorize an arbitrary transaction arbitrary, is not capable of arbitrarily changing the challenges sent by the bank (would cause an error verification authenticity). Once the adversary is not able to modify the challenge, the customer can verify the transaction data and determine if the operation has not been requested by himself, and therefore abort the process.

### 3.1. Premises and Functional Definitions

The proposed protocol uses channel separation and strong encryption (AES-256 and HMAC-SHA256) to ensure secure, independent authentication, preventing sensitive data from being intercepted. Visual verification with QR codes enables offline authentication, eliminating transmission risks. The authentication key is securely generated and stored without user knowledge, protecting the system from social engineering attacks. Additionally, the protocol is independent of specific hardware and software, reducing vulnerabilities associated with particular platforms. Each transaction has a unique code with limited validity, complicating interception attempts and quickly mitigating unauthorized actions, thereby enhancing transaction robustness and privacy.

The essential premises to ensure that the protocol meets all interaction requirements between the user and the server, as well as to clarify what can be accepted or rejected, are crucial for defining the proposal. Thus, the following functional premises are listed:

1. Every message generated will have a lifespan of up to 120 s, including encrypted messages.
2. All interactions will be authenticated.
3. A lack of response within 120 s will result in the cancellation of the ongoing transaction.
4. The response time for transaction authentication and authorization must be less than 2 s under normal operating conditions.
5. No connection to the mobile device is required.
6. Resistant to brute-force, man-in-the-middle, phishing, malware, and replay attacks.
7. The cryptographic keys used must be protected.
8. It should utilize encryption with keys of at least 256 bits (AES-256) and authentication based on HMAC-SHA256.
9. It must be developed with a modular architecture, allowing security updates to be applied without the need to interrupt the system.

These functional premises ensure that the DAP protocol not only fulfills its intended functionalities but also delivers a secure, efficient, and user-friendly solution, with a strong emphasis on providing a smooth user experience while meeting the system's operational and compliance requirements.

### 3.2. Definitions for a Protocol Using Two-Factor

Internet Banking systems are complex, based on different components, such as hardware, software, and communication infrastructure, which allows adversaries to monitor and modify data at different points of communication, mainly in customer machine. Even the classic attacks models present in the current literature do not adequately address the specific peculiarities of Internet banking systems.

In this proposal, the authors consider the application of three fundamental concepts of success, for a security model is strong enough to withstand an attack, and discourage the adversary to obtain the collaboration from client every time you submit a message. In this context, the attack model must consider the following hypothesis.

**Hypothesis 1:** *The computer where the transaction is executed may be compromised.*

**Hypothesis 2:** *It is very difficult to protect the application.*

**Hypothesis 3:** *It is very difficult to protect the customer.*

Considering the three fundamental concepts described by the Hypotheses 1–3, it's convenient to affirm that the protection developed for Internet banking systems is based on the reaction, and thus it becomes difficult and inefficient to detect new malware's. Even in identification models based on what the customer has, the adversary may gain access to trusted systems, and thus make transactions from the equipment or compromised application.

We consider a model that uses two-factor authentication, in this case a mobile device is used, which should have the capability to collect information using a camera and client software using the concept of symmetry of cryptographic keys, that will be generated from any device that has the capacity to perform small mathematical operations, store cryptographic keys  $k \in \kappa$ , in the sample space  $\kappa = \{0, 1\}^{512}$ .

The proposed protocol includes the authorization model based on a message associated with a random authorizer code, where a key is shared between the two parties over segregated channels. A symmetric system of consistent algorithms running in polynomial-time computation (Gen, Enc, Dec).

Suppose a customer gets a key  $k \in \kappa\{0, 1\}^{512}$ , which is divided into two parts  $k'_1 \in \{0, 1\}^{256}$  e  $k'_2 \in \{0, 1\}^{256}$  (Table 1), being the initial part  $k'_1$  associated with the integrity and authenticity of the message and the second part  $k'_2$  confidentiality associated with the authorized code  $r \in \{0, 1\}^{64}$  of a particular message or transaction. Assume  $Gen(1^n)$  has as output  $k$ , meeting of the sample space  $k = \{0, 1\}^{512}$ . Table 2 shows the format of the messages that will be used to send and process the messages  $m$ .

**Table 1.** Formatting and division of the message  $k$  in  $k'_1$  and  $k'_2$ .

| HMAC KEY                   | AES KEY                     |
|----------------------------|-----------------------------|
| 256 bits (32 Bytes) SHA256 | 256 bits (32 Bytes) AES 256 |

**Table 2.** Message layout  $m$ .

| HMAC KEY                   | AES KEY                     | Transaction |
|----------------------------|-----------------------------|-------------|
| 256 bits (32 Bytes) SHA256 | 256 bits (32 Bytes) AES 256 | 120 bytes   |

An external device is used as the second factor for authentication; in this approach a mobile device is capable of obtaining an image through an embedded camera and has the ability to run a dedicated application with a minimum set of mathematical processing. This device, receiving information on the transaction, verify the authenticity and integrity of data and then decrypts the data, with the purpose of issuing a code for authorizing a specific transaction.

A bank that offers online customer services must consider the concept of transaction authentication, allowing information to be confirmed externally to the communicating device, in this case a connected computer. This ensures that a message can be authorized with integrity, confirming that what is seen is indeed what should be authorized.

The proposal considers a system composed of two parts, a remote server for financial transactions and the user, which can interact through three different devices connected to their respective channels:

1. Automated Teller Machine (ATM);
2. The user's personal computer or any other device connected to the Internet;
3. The user's mobile device.

A scenario is considered in which a user connects to a remote server and needs to provide credentials for authentication, while an adversary, who is willing to perform arbitrary operations, possesses the following characteristics:

- The adversary has complete control over the user's personal computer through a malicious program or code installed and/or executed on the user's device. Therefore, the adversary can monitor all messages exchanged via the Internet channel between both parties (user and bank) and arbitrarily interfere with the communication, modifying, inserting, or deleting any information.
- The adversary is capable of monitoring and capturing all the information provided by the user.
- The adversary does not have control over the bank's ATM terminal but can obtain information displayed on the screen and data provided through the user's direct interaction with the terminal.
- The adversary cannot obtain any information directly from the user's mobile device.
- The adversary does not have access to the user's identification card (smartcard).

Suppose that the user wants to send an encrypted  $m$  message  $C$  to the bank using the model proposed in this article, and that an adversary can intercept the  $C$  message.

The security of the model will be guaranteed if the adversary is unable to discover encrypted information  $C$  with a finite key  $k$  from  $m$ , where  $k \in \kappa$  and the encoding functions are defined in  $E_\kappa$  and the decoding functions are defined in  $D_\kappa$ . Here, the probability of the message is given by  $p$  as  $Pr_\rho(p)$  and the probability of a key  $k$  is given by  $Pr_\kappa(k)$ , both determined by the probability in the space. Then it is possible to define the probability that a message is encoded by the key  $k$  through the expression (1).

$$Pr(p, k) = Pr_\rho(p)Pr_\kappa(k) \quad (1)$$

For the probability distribution of  $Pr$  in the sample space  $\rho \times \kappa$ , consider  $p$  a plaintext to denote the event  $\{(p, k) : k \in \kappa\}$  of being encoded. The probability is given by the expression (2).

$$Pr(p) = Pr_\rho(p) \quad (2)$$

Then, for a key  $k \in \kappa$ , denote  $k$  as the event  $\{(p, k) : p \in \rho\}$  that  $k$  is chosen for encoding, as given in expression (3).

$$Pr(k) = Pr_\kappa(k) \quad (3)$$

Therefore, events  $p$  and  $k$  are independent, because for a ciphertext  $c \in C$ , denote  $c$  as the event  $\{(p, k) : E_k(p) = c\}$  that the encoding result is  $c$ .

It follows that the adversary has knowledge of  $Pr_p$  of the plaintext, as there is no obscurity in the communication protocol between the legitimate source and the destination. Therefore, the ciphertext  $c$  is known to the adversary. According to the less likely probability distribution  $Pr_p$ , the adversary might discover something by observation of  $c$ . However, in contrast, if the probability of each  $c$  remains unchanged, then the adversary discovers nothing. According to Shannon [21], this motivates the concept of perfect secrecy. The access control of encrypted data can also be utilized in cloud storage systems [22].

### 3.3. Description of the Model

The description of asymmetrical and symmetrical communication model between the customer and the financial institution, where is set four steps to symmetrical model and three steps for the asymmetrical model. Both models are detailed in Sections 3.3.1 and 3.3.2 respectively. The protocol is detailed in the diagram in Figures 1 and 2. The proof of concepts for the validation of cryptographic algorithms is described in the git repository [23].

Modern cryptographic schemes are considered secure, with a negligible probability that these models will be compromised. It can be stated that execution in polynomial time is feasible, while execution in non-polynomial time has an insignificant probability of success.

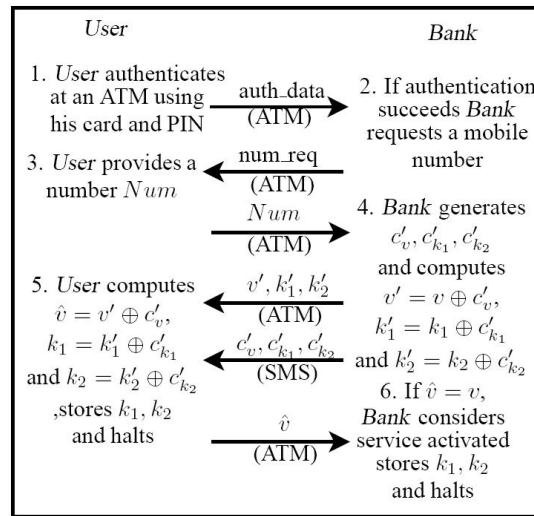


Figure 1. Key Change.

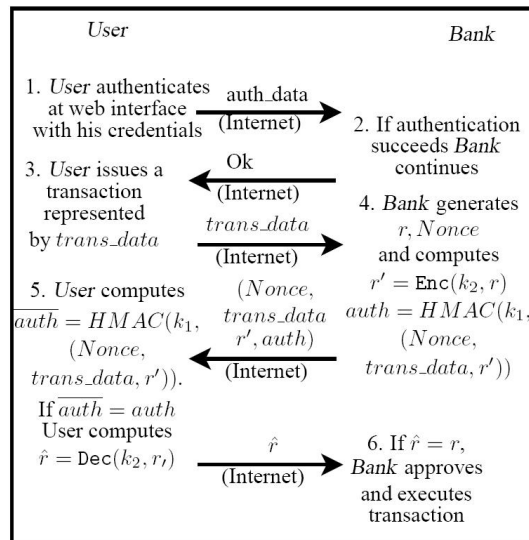
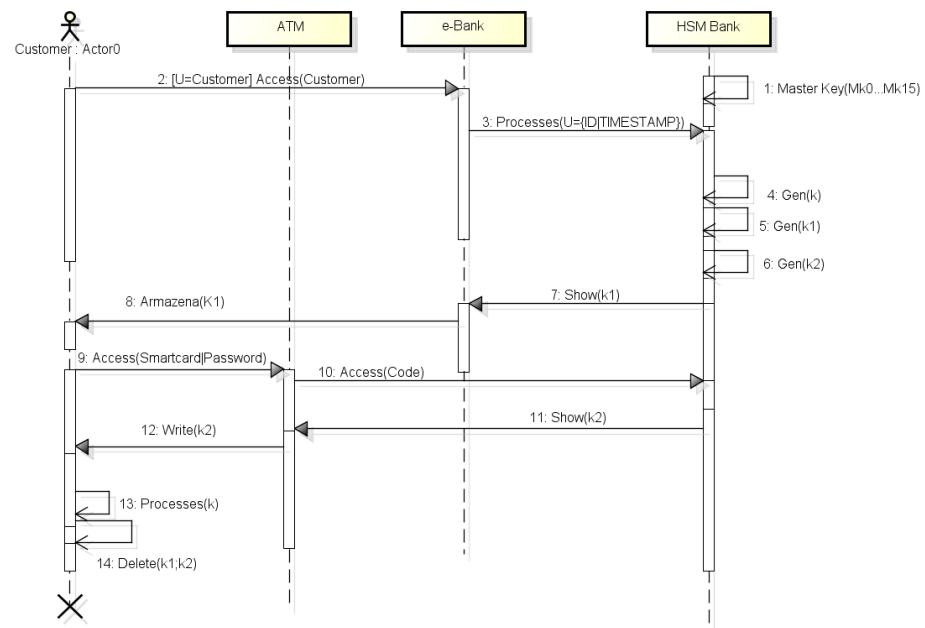


Figure 2. Authentication Messages.

### 3.3.1. Symmetric Model

The adversary to succeed in his attack has a probability of  $\frac{1}{p^n}$  for some positive polynomials  $p$ . However, if the probability of breaking the scheme is asymptotically smaller than  $\frac{1}{p^n}$  for each polynomial  $p$ , then the scheme is considered secure.

The Customer must follow four steps outlined in Section 3.3.1, pertaining to the Symmetric Model, which serves as a proof of concept implemented in a major bank. The most complex step involves obtaining the cryptographic key, which occurs in two phases: first, physically, through access to an ATM. Following this step, the transaction authorization is completed on the user's mobile device, which, upon possessing the key, is able to decrypt the transaction data, generate the authorization code, and finalize the banking transaction. This process is detailed in the diagram Figure 1 Key Change and Figure 2 Authentication Messages and Generation of seeds Master Key presented in Figure 3.



**Figure 3.** Generation of seeds Master Key.

- Step 1:** The customer authenticates himself using the Internet channel and requests permission to use the system as a second factor authentication, and installs application developed specifically for your model of mobile device.
- Step 2:** The mainframe system generates the cryptographic keys, using as input a unique identifier for each customer represented as *id* and the time that the customer requests this service, represented as *timestamp*. Along with masters keys, these inputs are processed and result a single key for each customer. The mainframe system returns to the e-Bank system, where the customer is already authenticated, the key  $k_1$  will be presented through a visual code generator.
- Step 3:** Customer using a mobile device and specific application, retrieves the key presented visually by e-bank system and stores the information, is then directed to an ATM terminal to complete this operation.
- Step 4:** The user authenticates himself into an ATM, owned by the financial institution, and the mobile device captures the second part of key ( $k_2$ ) generated in Step 2. The mobile devices processes the keys captured ( $k_1$  and  $k_2$ ) and stores the key  $k$ , this operation will be explained in detail in the following section.

The probability of an adversary succeeding is negligible for any inverse polynomial, according to the following definition:

A given function ( $f$ ) is negligible for all polynomials  $p(l)$ , where there  $N$  for every integer  $n > N$ .

For every constant  $c$  exists a  $N$  for all  $n > N$  supported by  $f(n) < n^{-c}$ . Therefore, any polynomial  $p(l)$  and all values from  $n$  sufficiently large such that  $f(n) < \frac{1}{p^n}$ . Figure 3 presents the steps for generating and exchange keys  $k$ ,  $k_1$  and  $k_2$ , so that no key part  $k$  is retransmitted directly from any communication channel. We consider that the customer is authenticated with the usual model adopted by the financial institution.

The financial institution *HSM Bank*, considered a secure environment that has a set of master keys  $MK_{k_1}, \dots, MK_{k_n}$  where  $MK \in \{0, 1\}^{256}$  obtained with  $MK \leftarrow \text{Gen}(1^n)$  generate a key  $k \in \kappa$  for each customer, where  $k \leftarrow \text{Enc}_{mk}(ID|timestamp)$ , using premises as any unique identifier associated with a date and time determined by the banking system at the time of key generation  $k \in \{0, 1\}^{512}$ . It is possible from  $k \leftarrow \text{Enc}_{mk}(ID|timestamp)$  recover  $k$  without the need to store  $k$ .

At first glance, this model is considered insecure and low-cost, as both  $w$  and the access credentials are static, making it susceptible to credential theft attacks, which are deemed trivial.

The same applies to one-time passwords, where a new password is requested at each new user connection, following the sequence  $f(w_1), f(w_2), \dots, f(w_n)$ . This makes the model seemingly more secure; however, this type of challenge can be easily bypassed when an adversary seeks the involuntary cooperation of a legitimate user to obtain the password. Similarly, models based on a pre-shared key are vulnerable, where the challenge is to identify a user, based on  $w_i = f^i(w), i \geq 0$ .

It is possible to conclude that an adversary gains an advantage when a system relies on static or dynamic passwords to identify a user. However, when a model incorporates a second factor, not for identification but for authorizing a specific transaction, the model becomes more robust. The challenge, however, lies in the transmission of a key  $k$  using two channels, where one of the channels is considered insecure and controlled by the adversary.

The diagram presented in Figure 3 illustrates the *HSM Bank* module, which is considered a secure environment containing a set of master keys  $MK_{k_1}, \dots, MK_{k_n}$  where  $MK \in \{0, 1\}^{512}$  and is generated using  $MK \leftarrow \text{Gen}(1^n)$ . A key  $k \in \kappa$  is generated for the user, where  $k \leftarrow \text{Enc}_{mk}(ID|timestamp)$ , with the premise that any unique identifier associated with a specific date and time, determined by the banking system at the time of key generation, can be used for  $k \in \{0, 1\}^{512}$ . The key  $k$  is then stored in a secure place.

The next step is to compute  $k_1$  and  $k_2$ , where  $k_1$  is a random string of size  $b = 2^{512}$  and  $k_2$  defined by  $k \oplus k_1$ , where  $k_2$  have the same size as  $k_1$ . The customer gets the key  $k_1$  from the insecure channel, where the adversary can access and store information, however  $k_2$  is submitted and recovered by the customer over a secure channel. Therefore, the key distribution is associated with a perfect secret scheme, where a particular fixed length message  $M$  and arbitrarily  $m \in M$  and  $c \in C$ . In the following equation, it is possible that the operation involved in determining  $k$ .

$$\begin{aligned} \Pr[C = c|M = m] &= \Pr[M \oplus k = c|M = m] \\ &= \Pr[m \oplus k = c] = \Pr[k = m \oplus k = c] = \frac{1}{2^{512}} \end{aligned} \quad (4)$$

The process is detailed in Figure 4, communication with the actors involved: *UC* (untrusted computer) represents a personal device with an Internet connection that the customer uses to communicate with the financial institution, as discussed in Section 4. This device is (not) susceptible to minimal protection, so it is considered untrustworthy. The (*mobile device customer*) must have the application developed by the financial institution and have the minimum requirements necessary to process some mathematical operations and store a cryptographic key. Finally, the Internet banking service provider (*e-Bank*).

The customer authenticates with static credentials  $w$  (account number plus password) and requests the sharing of the secret  $k$ . The financial institution (*e-Bank*), after validating access as legitimate, sends  $k_1$  presenting the key information using a visual code (i.e., QRcode) through the screen of the personal device *UC*.

The customer, using his mobile device, processes and stores  $k_1$ . The customer is informed to continue the process and collect the remaining information  $k_2$ , finishing the secret key construction process  $k$ . The e-Bank system records the information that the key  $k_1$  was provided to a specific customer. The last step of the key exchange process is shown in Figure 5. At this moment, the customer can now fully utilize his mobile device as a second factor authentication.

The actors involved in this stage are: *ATM* (ATM banking) and *customer's mobile device*. At this stage, the customer is challenged to prove their identity using two factors: a card's bank and your personal password static (PIN). After verifying and validating the customer's identity, the second part of the secret  $k_2$ , visualized directly on the terminal screen *ATM*, using the same process shown in Figure 4, a visual code (QR code) containing key information  $k_2$  displayed to the customer, a mobile device screen shoot, processes and stores the key  $k_2$ .

The mobile device is capable of processing keys  $k = k_1 \oplus k_2$ , store  $k$  and discard  $k_1$  and  $k_2$ . At this stage, the process is completed; a secret was exchanged between the customer and financial institution. The customer can now be challenged and receive a message  $m$  and encrypt  $m' = E_k(m)$  so that when you run  $D_k(m')$  and if  $m' = m$  accept the message.

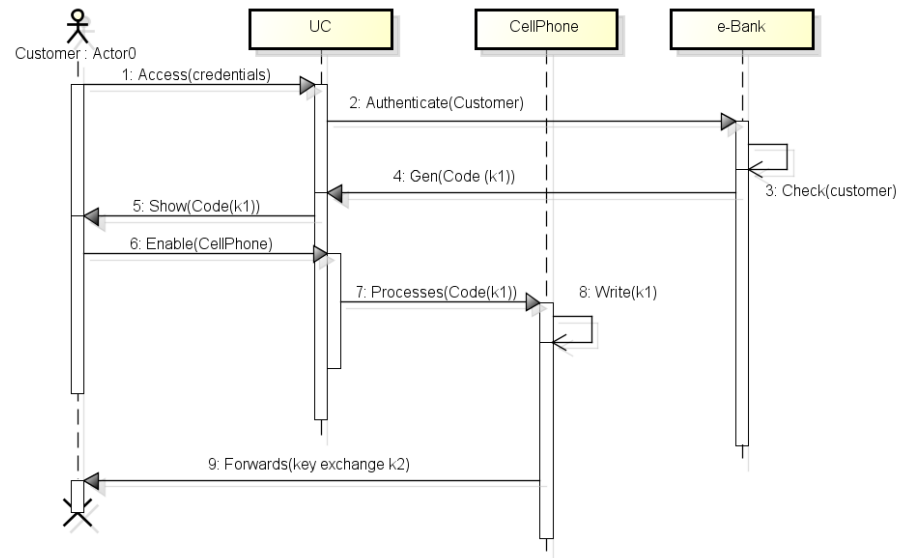


Figure 4. Key Exchange— $k_1$ .

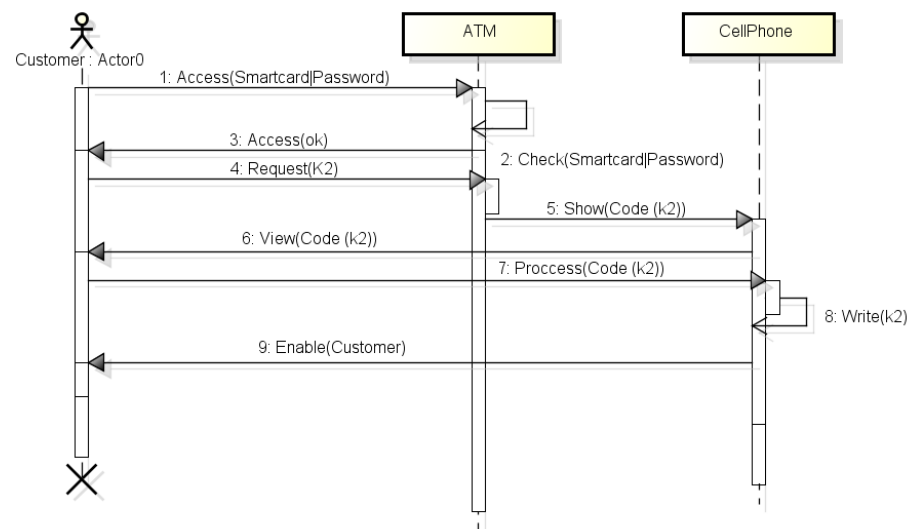


Figure 5. Key Exchange— $k_2$ .

### 3.3.2. Asymmetric Model

The complexity of the symmetrical model [24], discussed in Section 3.3.1, mainly deals with the problem of distributing a key  $K$  in a secure manner.

Communication between all parties is necessary, increasing the complexity of the model and making administration costly. For a system that has  $n$  users, it would be necessary to have  $n(n-1)/2$  secret keys. However, the proposal of this research is that communication is always between the customer and the financial institution, never between the customer, therefore even in asymmetric systems, that the number of keys is  $2n$ , not affect the number of keys, which remains the same for both models.

**Step 1:** The customer authenticates himself using the Internet channel and requests permission to use the system as a second factor authentication, downloads and installs an application developed specifically for its model of mobile device and generates  $Gen(1^n)$

the keys  $Pk, Sk$  through hardware-based processing where  $Sk$  is a non-exportable private key.

**Step 2:** Customer uses the business model of public key infrastructure (PKI) presenting an Authority to Register (AR) for authentication by a Certificate Authority (CA) financial institution.

**Step 3:** Customer receives digital certificate authenticated by the CA of the financial institution and the process of enabling ends.

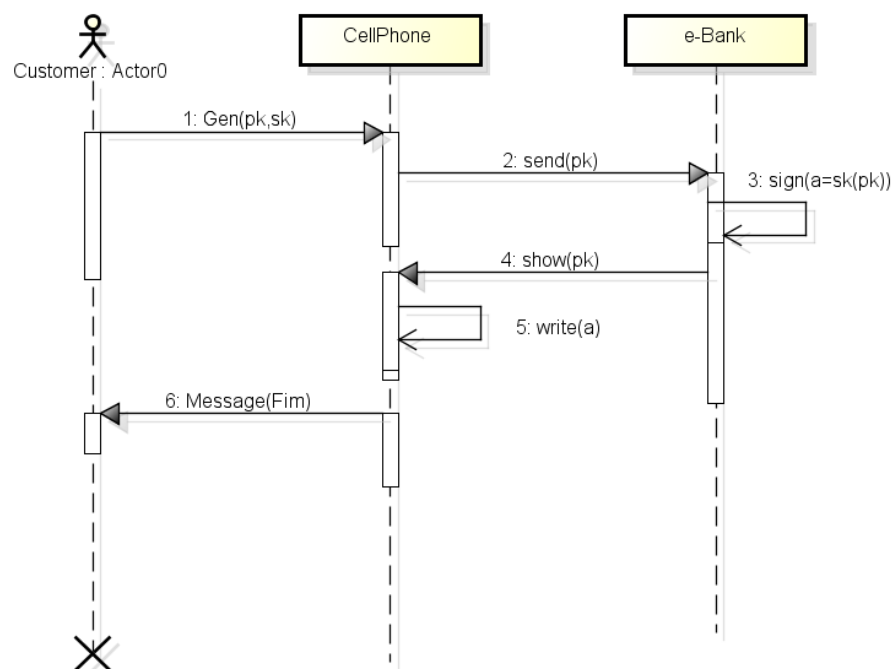
**Definition 1.** A public key scheme is a probabilistic tuple of a polynomial-time execution algorithm  $(Gen, Enc, Dec)$  that:

1. The algorithm  $Gen$  generates a pair of keys  $pk, sk$  with input parameter  $1^n$ .  $pk$  refers to the public key and  $sk$  is the private key. It is assumed that  $pk, sk$  have size  $n$  and that  $n$  is determined by  $pk, sk$ .
2. The encryption is given by  $Enc$ , which takes  $pk$  and a message  $m$  as input, where  $m$  is a plaintext. The output is a ciphertext  $c$ , which can be expressed as  $c \leftarrow Enc_{pk}(m)$ .
3. The decryption is given by  $Dec$ , which takes the key  $sk$  and the ciphertext  $c$  as input, and the output message can be  $m$  or  $\emptyset$ , denoting a failure. It is assumed that  $Dec$  is deterministic, and that  $m := Dec_{sk}(c)$ .

The output is required to be negligible ( $negl$ ) given any  $n$ , for any  $pk, sk$  and output  $Gen(1^n)$ , and each message  $m$  for the plaintext sample space is expressed in (5).

$$Pr[Dec_{sk}(Enc_{pk}(m)) \neq m] \leq negl(n) \quad (5)$$

The key generation model [25] is based on hardware (Figure 6), where the mobile device must be able to perform all mathematical operations of the public key infrastructure model (PKI).



**Figure 6.** Asymmetric cryptographic keys Model.

For this scheme to be strong enough, we consider that an adversary is not able to compute in polynomial time any message encrypted  $c$  and obtain  $m$ , without having  $Sk$ . Therefore, is defined that is computationally not feasible to obtain  $k$ , even knowing the algorithm or protocol used to encrypt  $m$ .

This model describes the RSA public-key algorithm, where a user executes  $Gen(1^n)$ , obtaining  $(N, e, d)$ , with  $sk = (N, d)$  and  $pk = (N, e)$ , following the same approach presented in Definition 1.

### 3.4. Exchanging Messages

The customer will be able to verify the authenticity of the message  $m$ , in the same way as it is possible to ensure the integrity of the information, defined by function  $h_k(m)$ , and then check if  $m$  has been modified after computing  $h_k m' = h_k(m)$ . The mobile device should be able to perform the operations that verify the integrity and confidentiality. The customer uses the key  $k$  stored on his mobile device, which is known to the financial institution, previously shared and presented in Sections 3.3.1 and 3.3.2. The key length is 512 bits, where  $k \in \{0, 1\}^{512}$  and is divided into two parts  $k'_1 \in \{0, 1\}^{512}$  and  $k'_2 \in \{0, 1\}^{512}$ .

With the keys stored on the mobile device, the user will be able to verify the authenticity and integrity of the transmitted information, in addition to ensuring its confidentiality. If the authenticity and integrity of the information is confirmed, the user can choose to confirm or reject the message.

When a customer, previously authenticated to the system in a conventional manner, using an untrusted computer (UC) and connected to the Internet, requests a transaction, conveniently called  $m$ , the customer's key  $k$  will be recovered, to begin the process of authorizing the requested transaction. The authorization of a message  $m$  is determined using an authorizer code  $r$  associated with this message.

$r \in \mathbb{N}$  is then generated, where  $\mathbb{N}$  is the set of positive integers, and  $\mathbb{N} \in x_1, \dots, x_{999999}$ . Pseudorandom models provided by computational systems are used, with a sample space of  $0 < r \leq 999999$ , where the set of numbers is uniformly distributed within the sample space. This can be demonstrated through expression (6).

$$r = \sum_{i=1}^n x_i 2^{n-i} \quad (6)$$

The authorizer code is then encrypted with the key  $k'_2$  in  $r' \leftarrow Enc_{k'_2}(r)$ , and the mobile device is able to compute  $r' := Dec_{k'_2}(r)$  showing the authorized customer code  $r'$ . The diagram shown in Figure 7 demonstrates the sequences involving the customer and an untrusted computer (UC), a mobile device (cellphone) and the financial institution server.

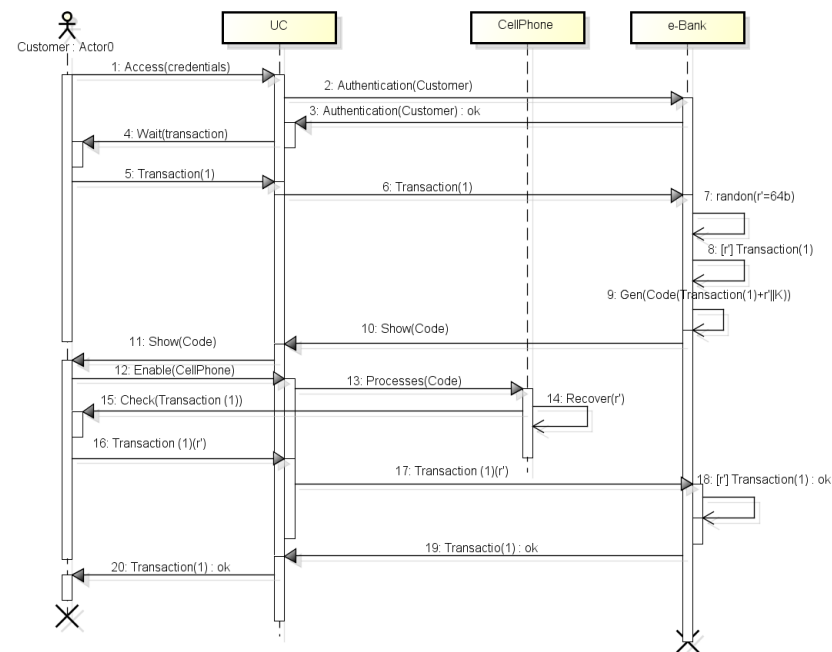


Figure 7. Transaction authorization flow.

The financial institution pred sends a challenge using a visual code (QR-Code) and the customer, using a mobile device (cell phone), captures the visual code (Figure 8).

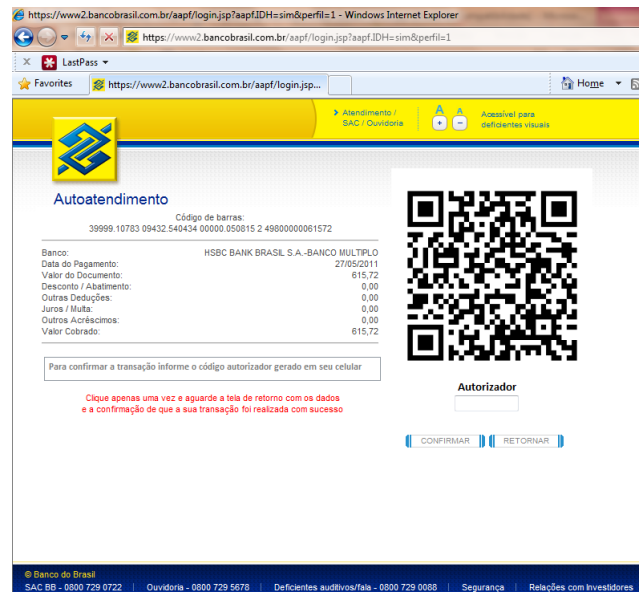


Figure 8. Challenge response displayed on the untrusted computer.

The financial institution receives and processes the message  $m$ , following the layout described in Table 2, computes  $y = h_{k_1}(m, r')$ .

Message  $m_i$  is displayed requesting the channel, the mobile device the customer, using a camera, then retrieves visually  $m_i$ . The mobile device validates  $m_i$ , checking the authenticity and integrity of the message.

Then if  $y' = y$ , the message  $m$  is considered authentic and integrity, because the adversary, without knowing the key  $k'_1$ , is impractical to obtain  $y, y'$ . At that moment, the customer can recover the message, which is shown in Figure 9. Confirming the information displayed, the customer sees the authorization code (Figure 10) that must be inserted into the requester channel, in this case an untrusted computer. The authorization code is valid only for the transaction that is executed and cannot be reused, unlike a one-time password (OTP).

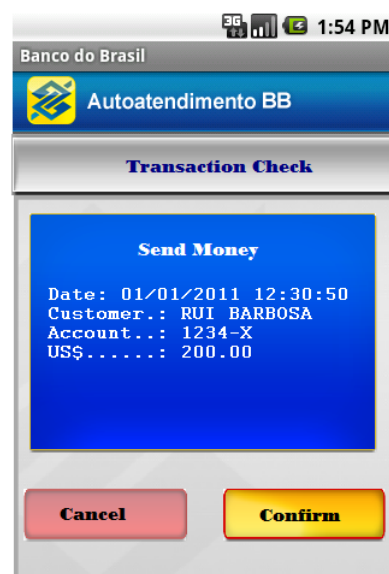


Figure 9. Cellphone transaction check.

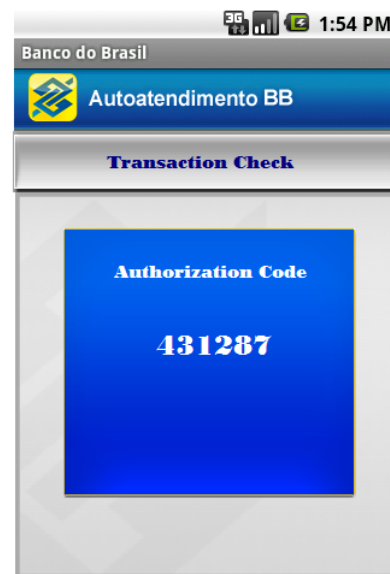


Figure 10. Cellphone authorization code view.

The final communication sequence involves sending  $r'$  through the channel that initiated the transaction, as illustrated in Figure 10. Then,  $r'$  will be provided by the user on the original channel from which the message  $m$  was requested. Upon receiving it, the bank will calculate  $r' = r$ , and if the values match, the challenge is accepted and the message is confirmed. The same proof applies here: without knowledge of  $k'_2$ , an adversary lacks the computational capability to derive  $r$  or  $r'$ .

The success of an attack against this approach depends on the ability of the adversary to compromise the customer's mobile device, in the description of the adversarial model presented in Section 4 being considered infeasible. Likewise, a description of the attack based on legitimate customer collaboration is possible and is considered; however, the adversary must persuade the customer to perform arbitrary operations. This type of action, although expected, hampers most recent attacks that use the automation and personification, and still needs constant collaboration, from the customer, for all transactions required.

#### 4. Scenarios and Adversary Model

Since the user's personal computer is considered vulnerable to various attacks, as presented in Section, it is relatively easy to compromise it using malicious code and/or programs. The use of such malicious code is commonly observed in attacks targeting computers that use banking systems.

Attackers aim to capture sensitive information, such as authentication data, credentials, and passwords, and gain full control over the user's personal computer by infecting it with malware or other malicious code. Since the user machine is typically vulnerable to various attacks, gaining access and control through malicious programs is not difficult. This strategy is frequently observed in attacks against Internet banking systems, where attackers successfully steal authentication data and arbitrarily forge transactions. Additionally, this approach is often the most cost-effective and secure for attackers, requiring only the installation of malicious software, while typically leaving insufficient forensic evidence to identify the perpetrator. In this context, malicious software often downloads code from a remote site, interacts with system banks, and uploads the data collected from the infected machine to another remote location.

To enable Internet banking access, many financial institutions require users to request such services through an Automated Teller Machine (ATM). Therefore, it is necessary to consider the security of these terminals and the type of information an adversary might extract or insert into these devices. Although it is relatively easy for an adversary to monitor the screen and keyboard of an ATM, it is unnecessary to consider the scenario where the

adversary can arbitrarily control the terminal, as this would give the adversary all the necessary credentials to perform any type of transaction directly at the ATM. Information input and output from ATMs are typically monitored using common cameras, sensors, and false devices such as card readers and keyboards, known as “skimmers”.

Adversaries generally have limited access to a user’s mobile device, as it is more difficult to infect these devices, monitor them, or alter the network they are connected to. The operating system of a mobile device is custom-built and minimalist, with few services available to external users, resulting in a lower probability of compromise compared to personal computers. For instance, mobile networks, such as GSM, make it difficult to track, alter, or inject information, requiring sophisticated, high-cost equipment and proximity to the user’s mobile device. To ensure an acceptable level of security for the communication channel between the user and the bank, various solutions are continuously tested and implemented to address issues related to confidentiality, integrity, authenticity, and non-repudiation.

Current banking systems are affected by numerous vulnerabilities that allow attackers to execute arbitrary operations in legitimate user accounts. However, in the current literature, there is no formal definition of the ideal security for Internet banking systems or how adversaries can attack them. This section will discuss how attackers can compromise multiple devices and channels involved in these systems, proposing an adversarial model that captures the capabilities of modern adversaries across different levels of interaction that they can execute on existing components.

In this research, we will consider a system composed by two legitimate parts: financial institution and customer, and an illegitimate part: adversary. It also considered that these parts communicate through three different environments in their respective channels:

1. ATM (Automatic Teller Machine) directly connected to the network of financial institution.
2. Customer personal device connected to the Internet.
3. Customer Mobile Device.

The adversarial model considers that the adversary is willing to make arbitrariness transactions that has the following characteristics:

- The *adversary* has control over everything the customer does in his personal device. The *adversary* is capable of monitoring all messages exchanged through the Internet and arbitrarily interferes with the protocol by inserting arbitrariness messages.
- The *adversary* has the ability to monitor all the client’s information, such as what goes in and out of the financial institution through a terminal ATM. However, he cannot control the terminal ATM and cannot enter or modify any message on it.
- The *adversary* does not control the customer mobile device and is unable to obtain or modify any information stored on it. It is not able to monitor a private communication between a customer and financial institution, or tamper with any type of information exchanged in this conversation, nor transmit information as a legitimate customer.

Ideally, Internet banking systems should not allow an adversary to perform arbitrarily or change the content of the operations issued by a legitimate customer. While it may be difficult to guarantee privacy in a compromised environment (as the customer personal computer), the Internet Banking Systems must be able to prevent unauthorized persons or malicious actions from performing financial transactions as legitimate.

The protocols used to process these transactions, has a basic approach: the customer provides number account plus password and information about the transaction. These protocols must first guarantee that the customer is really who he claims (like an identification protocol), and only after this initial step is it possible to authorize a transaction, rightfully emitted by the customer. If the identity of the customer and the authenticity of the transaction are confirmed, the transaction is authorized.

The formal definition of protocols for transaction authorization [26] is given by Definition.

Considered a process of authentication between the customer and the financial institution that communicates over different channels, like an ATM s, a website, and mobile

networks. The authorization protocol is considered secure if the adversary is not capable to forge a legitimate transaction, personifying a legitimate customer.

Observe that is not required, from authorization protocol, the confidentiality of transactions. However, it is expected to be possible to prevent the adversary can personify a legitimate customer and submit new transactions. These protocols are subjected to the same attacks that affect the identification protocols. Furthermore, they are subject to attacks where an adversary tries to arbitrarily change the transaction information sent by the legitimate customer, in order to forge transactions without tampering with legitimate customer identification.

#### 4.1. Attacks Models

Attack modeling is crucial to obtain a complete understanding of threats. Using the concept of an attack tree for threat analysis [27], it allows better understanding of the complex risk landscape.

It is possible to classify into two groups: passive attacks and active attacks [28].

Passive attacks make use of models to capture credentials that are stored and used later. This attack generates two possibilities: use offline or online.

**Offline Attack** The adversary selects a customer that has an access to financial institution, and uses its information to fraud the customer's account. This type of attack depends on the installation of any malicious program, such as a keylogger or such a variant. Customers may be victims of such an attack simply because they write down or store unencrypted passwords in a textfile accessible on a local hard disk.

**Online Attack** The adversary randomly selects customers, seeking to affect the largest number of users connected to the Internet. They use techniques to exploit remote vulnerabilities or phishing methods.

Active attacks are regarded the most sophisticated, requiring extensive knowledge of the adversary [29]. Such attacks are typically targeted at customers of financial institutions with the intent of compromise their security [30]. The goal is to deceive a legitimate customer into divulging credentials or performing operations that deviate from their usual behavior. This approach contrasts with simply shifting the responsibility for security from the service provider to the customer, as it involves identifying vulnerabilities that can be exploited to undermine the security model [31].

The attack vector that employs phishing techniques [32] leverages a trust base to succeed in its exploitation. This type of attack primarily aims to steal sensitive data that allows an attacker to impersonate a legitimate user.

The content of a phishing email is based on misleading information [33], which, through social engineering techniques [34], appears to be trustworthy and legitimate. Induces a legitimate user to follow the instructions contained in these messages, relying on the user's involuntary or careless cooperation, or on the user's lack of knowledge, which leads them to believe that the information presented is true. This attack can be divided into two main modules:

1. Off-Line: Information is stolen and used without the legitimate user's cooperation. Static authentication, where the information needed to access a system remains unchanged.
2. On-Line: Information must be stolen or requested when some event occurs, requiring the legitimate user's participation. Dynamic authentication, where the information needed to access a system varies with each login attempt.

The success of this exploitation is strongly associated with various attack vectors. Since phishing attacks form the base of the attack tree. They are associated with other vectors, such as embedding phishing in search engines, where the victim accesses a website believing that it is legitimate. Another example is link injection into legitimate websites via cross-site scripting attacks, which redirect victims to malicious sites. Additionally, vectors like spy-phishing or phishing based on malicious code (malware) rely on the

user's cooperation to install malicious software, such as a Trojan horse, which enables an attacker to monitor the infected machine's actions, collect the necessary credentials for access, or even control the machine remotely. It is also possible to alter DNS and local domain configurations (pharming), redirecting connection requests to a host other than the legitimate one.

For models that use static information to identify a client, phishing attacks are extremely efficient [35]. However, attacks associated with the technique for monitoring, creating and modifying a message is related to the *man-in-the-middle* and *man-in-the-browser* attacks [36], that are used across the financial scenario, including targeted attacks on ATMs, point of service that use smart cards and the EMV protocol (Europay, MasterCard and VISA), using a standard approach to identify a client with a personal password (i.e., PIN) and authorize transactions [37]. Therefore, it is very difficult to protect a customer in this type of attack, even when using an authorization based on personal transactions executed on the customer machines. This kind of attack is dependent on the control of a machine control using malicious code such as Trojan horses.

The security models that use PIN, TAN [12], digital certificates, on-time password tokens (OTP) [13], smartcards [38], or any other device inserted into a user's personal machine considered legitimate are susceptible to this type of attack. Essentially the models considered stronger, like tokens OTP or digital certificates can be used without any interaction from the customer, or in the case of blind signatures, where a legitimate customer authenticates a transaction that seems real, it actually is running another, in other words, the customer confirms the transaction sees, but the real transaction occurs without the knowledge the customer. Similarly, it is possible to intercept all communication between customer and financial institution, and in some cases request that informed codes OTP, or to insert a digital certificate, allowing the adversary to use all the expected features.

Attacks that use physical methods as a vector are considered traditional, where credential theft or physical device theft occurs directly in the user's environment [39]. Theft of the user's personal device, backups, access to stored information, mail intercept, attacker observation during system access ("shoulder surfing"), disguised ATMs ("skimming") that appear to be legitimate terminals but aim to steal passwords and magnetic card data [40], and retrieving information from trash bins ("dumpster diving") are all part of this vector.

Another type of attack associated with phishing and man-in-the-middle is control-relaying (RT-MITM). Involves an attacker capturing credentials and using them automatically, which requires the machine to be fully compromised and under the control of malware. In [41], a phishing protection model using CAPTCHA is presented, which challenges the user to prove that they are human, thus preventing automated attacks commonly called bots. However, an attacker can attempt to either decipher the code, if the model used is simple enough, or request that the trojan capture the image, send it to the attacker, who in turn responds to the challenge. In the proposal by [42], an additional variable is introduced by incorporating a second authentication factor based on OTP. Upon receiving the challenge, the user must provide an identification and the associated OTP code, which complicates the attacker's actions, but does not entirely prevent them. The user could still be manipulated through social engineering to provide the OTP code, or could be deceived via a blind signature, confirming an illegitimate transaction.

Given the set of credentials  $C = \{A, C, S_1, S_2, I\}$ , where  $A$  and  $C$  identified the set of credentials,  $S_1$  and  $S_2$  symmetric key for authentication,  $I$  equivalent to any hardware identification code that allows a customer to associate a single device with a specific account.

The adversary will be capable of run arbitraries transactions when obtaining  $C$  to reproduce  $I$  when necessary. The adversary can try to get  $S' = S_1, S_2 \in \{0, 1\}^n$  in polynomial-time choosing randomly  $f(S')$  we can deduce the probability  $P(S') = \frac{1}{2^n}$ . (However, since  $S_1$  and  $S_2$  are static secrets and not secured, the adversary can capture this information and use later [43]).

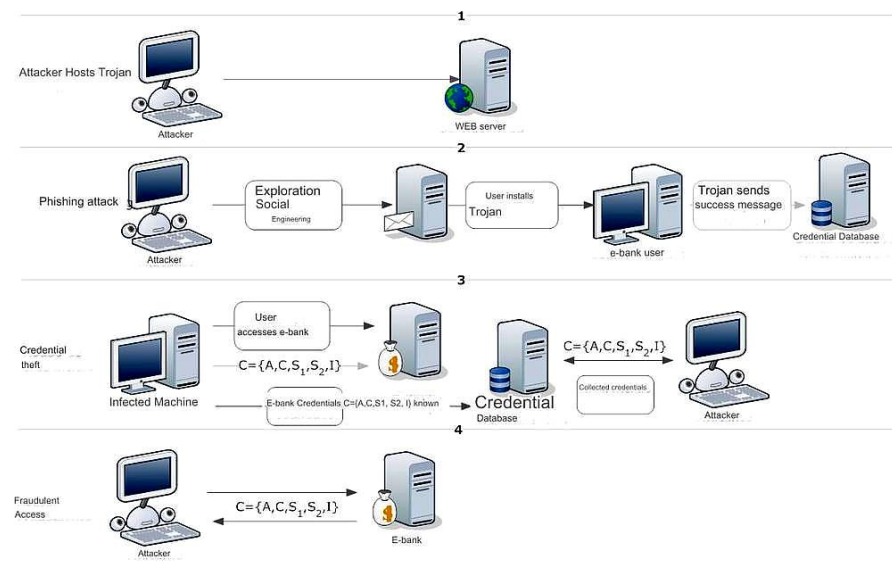
#### 4.2. Personification of Customer Attack

The adversarial model as presented in Section 4.1, the personification of a customer is the most common attack and relatively simple to develop. Figure 11, demonstrates this type of attack, using phishing as a vector. Basically, consists of obtaining the credentials  $C = \{A, C, S_1, S_2, I\}$  and the information required for the adversary to have the ability to personify a legitimate customer, reproducing information that only a legitimate customer should have.

The personification does not suggest using robust identification schemes, where there is a secret random challenge and response protocol, requiring the customer to prove their identity through what is known, or in the case of some banking models, what has. However, it is associated with the evaluated models and a shared secret knowledge of both, in contrast to an asymmetric system, where each entity knows a secret not shared.

The verification of identity through the use of a *zero-knowledge* proof has been an accepted paradigm for identification protocols [43]. However, this paradigm does not affect attacks that exploit a weak link, in this case, the legitimate user.

Given a set of credentials  $C = \{A, C, S_1, S_2, I\}$ , where  $A$  and  $C$  are the identifiable parts of the credential,  $S_1$  and  $S_2$  are symmetric secrets used for user authentication, and  $I$  represents a hardware identifier that links a user to a unique device.



**Figure 11.** Diagram Personification of Customer Attack.

An adversary can execute arbitrary transactions if they manage to obtain  $C$  and replicate  $I$  when necessary. It is assumed that the adversary may attempt to recover  $S' = S_1, S_2 \in \{0, 1\}^n$  in polynomial time by randomly selecting  $f(S')$ , with the probability of success being  $P(S') = \frac{1}{2^n}$ . However, since  $S_1$  and  $S_2$  are static and unprotected secrets, the adversary could capture this information and use it later.

This attack can be classified into four stages, in which the adversary compromises the machine of a legitimate user to gain unauthorized access.

**Stage 1:** The adversary creates a malicious artifact or a fake webpage and makes it available on the Internet.

**Stage 2:** Exploiting social engineering techniques or software vulnerabilities, such as those in browsers, the user's machine becomes infected with malware. When the user accesses the service, they enter their credentials, thinking they are interacting with a legitimate service. In reality, they are in an environment controlled by the adversary, who stores the collected information on an external server.

**Stage 3:** Once the adversary has gathered the necessary information to access Internet banking, the user is redirected to the legitimate service, typically without any noticeable errors. However, the user is asked to re-authenticate. The adversary then verifies the information that has been collected.

**Stage 4:** With all the required information, the adversary impersonates the legitimate user when accessing the service, even mimicking physical identification traits if the bank uses these to uniquely identify users.

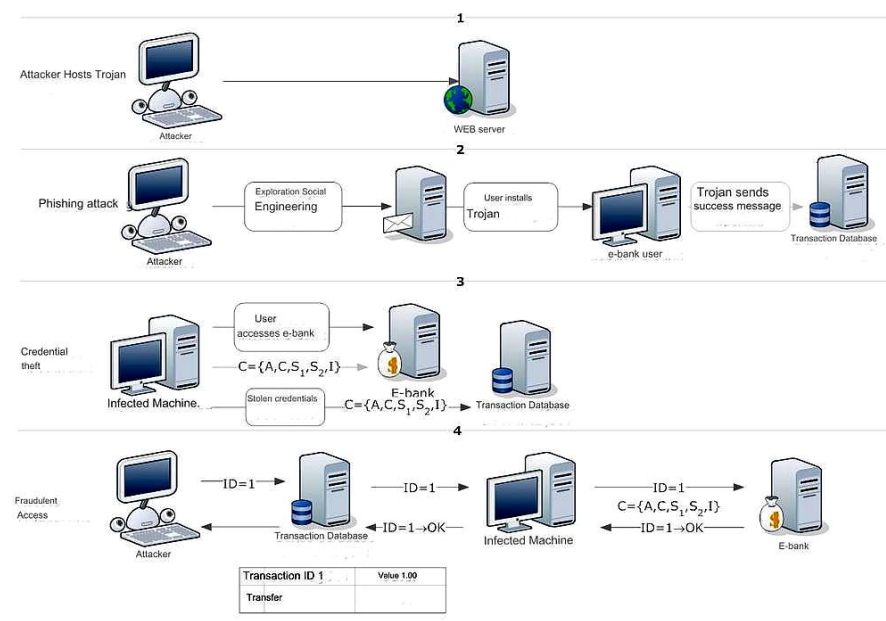
In this context, if the user's personal computer, which is used to access the remote site, is compromised, introducing any security solution that relies on this device will not improve security in the already compromised environment.

Now, consider that an adversary is capable of executing arbitrary transactions, and the bank trusts the messages as if they were sent by the legitimate user.

#### 4.3. Control Device Attack

In a device control attack, it is observed that there is a higher level of complexity compared to an impersonation attack. While user impersonation involves messages that are not only authenticated with information known exclusively to the legitimate user but also utilize what the user possesses, such as a known and identified personal computer. Therefore, tracing the source of the attack is considered challenging, as the adversary never directly connects to the bank, instead fully using the user's personal machine to execute arbitrary transactions.

This type of attack interferes in authenticity of messages sent from the premises affecting an information security, essentially financial institutions try to find a way to identify the customer and authorize access, considering two pillars: what is known (identifiers and passwords) and what you have (some kind of hardware). The adversary must be capable of control the personal device customer and reproduce your credentials  $C = \{A, C, S_1, S_2, I\}$  in order to possess all the characteristics, including physical, of a legitimate customer, Figure 12.



**Figure 12.** Diagram Control Device Attack.

**Stage 1:** The adversary makes a malicious artifact or fake webpage available on the Internet.

**Stage 2:** Exploiting social engineering techniques or vulnerabilities in software such as browsers, the user's machine is infected with some type of malware, which waits for

access to the Internet banking service and then collects credential information and anything else needed to authenticate.

**Stage 3:** Once the necessary information to perform the transactions is obtained, the malware (through the user's machine) checks an Internet repository, previously populated by the adversary, for the transactions that need to be executed.

**Stage 4:** The adversary uses malware that, having the user's credentials, authenticates with the bank and executes illegitimate transactions directly from the user's machine, without human intervention. When the user accesses the service, as long as the malware remains active, the information about the illegitimate transactions will be suppressed, making it difficult for the user to detect any abnormality. The adversary updates the transaction repository with additional transactions to be performed.

The taxonomy of this attack is characterized in a way that allows an adversary to compromise a legitimate user's machine, gaining the ability to execute arbitrary transactions directly from the device. The attack model can be divided into 4 stages.

## 5. Results Analysis

The protocol was implemented and tested at Banco do Brasil, a company with a presence in more than 13 countries, including Germany, Japan, the United States, China, the United Kingdom, Argentina, Bolivia, and Chile. It also operates through correspondents in more than 94 countries, with more than 3400 physical branches in Brazil and 86,000 direct employees.

In 2023, Banco do Brasil reported net equity of approximately 33 billion dollars, highlighting continuous growth, with a net income of 7.1 billion dollars. The bank processed more than 186 billion transactions in 2023 through various digital channels, such as mobile banking, internet banking, and payment systems.

Currently, Banco do Brasil serves more than 81.3 million customers, including 29 million active users on digital platforms and 23 million users of mobile apps.

Attacks are the result of the exploitation of a fragile entity that has some type of vulnerability that may or may not be the result of cooperation. A major problem is that there is no standard that defines the type of attack and the degree of impact because this same factor may be different for each scenario.

The main challenges are associated with safe development and the human factor [44], which is different for each scenario, but can be divided into:

- Difficult to build secure code
- Weakening security over time and features requested by the market
- Difference between the knowledge of the developer and the adversary

Building secure code becomes a challenge when put to the test with the search for vulnerabilities that are relatively easy compared to the production of truly secure code. Faced with this challenge, the analysis of the possibilities of a system compromise, based on the probability of occurrence or risk [45].

The risk of compromise, in these cases, is defined based on a probabilistic expression of the occurrence [44], strongly influenced by a set of indicators [2]:

- Technical difficulty;
- Cost of attack;
- Probability of successful attack;
- Expected conditions;
- Countermeasures.

These challenges contain information about the transaction to be authorized, as well as a unique confirmation message that the user must decrypt or sign with their secret key in order to successfully authorize the operation. Upon receiving a challenge, the user can verify whether it was genuinely sent by the bank and then review the transaction being authorized. If the challenge is authentic, it confirms that the operation was requested by

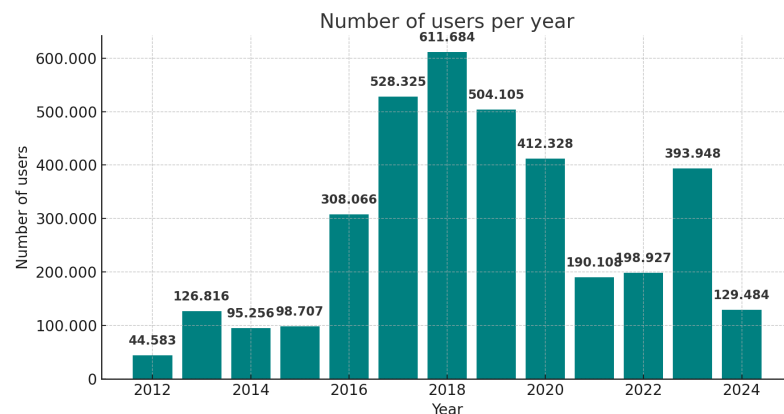
the user, allowing them to choose to perform the required operation (decrypt or sign) on the message and send it back to the bank, which then authorizes the transaction. Each unique message is linked to a specific transaction, enabling the bank to precisely determine which transaction the user is authorizing.

It would be impractical for the user to memorize both keys, interpret the challenges sent by the bank, and perform the necessary cryptographic operations on the confirmation message. Therefore, these actions must be performed on a dedicated device. If an adversary gains control of this device, they would be able to authorize arbitrary operations, as they would have access to both keys.

Taking into account the adversarial model presented in Section 4, operations are initiated on the user's personal computer and authorized via the user's mobile device (possibly a smartphone).

All transaction authorization operations are performed by an application pre-installed on the user's mobile device. Once a transaction is initiated on the computer, the Internet banking system sends the corresponding authorization challenge to the mobile device through a communication channel, presenting the information through 2D codes. The application verifies the authenticity of the challenge and displays the transaction details. The user confirms the information and may choose to authorize the transaction in the smartphone application, which performs the required operation (decryption) on the verification message and presents the result. The user then enters the resulting message into the Internet banking site, which authorizes the transaction.

This article is the result of the conclusion of a doctoral research completed in 2012 [46] and its implementation was carried out in one of the largest banks in the world. In Figure 13, we present the evolution of the usage of the solution, being the first protocol created for the authorization of financial transactions through the use of a QR code image. Currently, as of 07/2024, there are 3.6 million active users of the solution.



**Figure 13.** Number of Users.

Factors directly influence complexity, which can be defined as inversely proportional to its complexity. However, this becomes untrue when high complexity is required at a low cost, increasing the likelihood of the attack's success.

In Table 3, we present the results of the proposed solution for companies, where the percentage corresponds to devices that are already known and enabled for use.

Large companies have been using this solution to improve their security. This is due to the separation between those who perform a transaction and those who authorize it, allowing for segmented use and increased security for companies in case of failures or improper behavior by employees. Using more than one authorizer reduces the risk of internal fraud within the company.

**Table 3.** Number of Enabled Users—Companies.

| Type             | Total     | %      |
|------------------|-----------|--------|
| Companies        | 1.338.529 | 30.17% |
| Small Businesses | 1.242.296 | 29.84% |
| Big Companies    | 7.923     | 44.71% |
| Government       | 12.132    | 30.78% |

Strong demand generated by new access technologies often puts safety as a model of the background, generating a direct impact on usability, regarded as something impeding, but is strongly apparent when the impact is financial, generating losses on non-compliance with basic rules of security best practices. Short deadlines for a specific service is released is another risk factor, the lack of stringent testing creates insecure products.

The main challenge in implementing the proposed model was related to the generation and storage of cryptographic keys. To address this issue, a specific HSM (Hardware Security Module) was chosen to sign the user's key, which is generated based on unique information such as the ID, the timestamp of the key generation, and personal data like name and address. Information is not permanently stored on the system. With each use, the key is recalculated, the message is encrypted, and the key is discarded after use until it is needed again. Since the HSM is highly controlled and only responds to authenticated requests, the risk of compromise is significantly reduced, allowing the challenge to be successfully overcome.

## 6. Discussion

The lack of a standardized framework for security guidelines in banking transactions results in inconsistent practices between financial institutions, creating gaps in protection against cyberattacks. Without clear and specific standards, each institution adopts its own approaches and solutions, varying in effectiveness, usability, and complexity, which weakens the sector as a whole. This inconsistency allows attackers to exploit differences in security practices, adapting social engineering techniques and other attack methods to target more vulnerable institutions. The absence of standardized procedures for authentication, transaction verification, and secure key storage hinders the development of universal protocols that reliably protect customers and ensure data security and privacy.

The proposal aims to address the growing problem of security in online banking transactions, exacerbated by the increasing sophistication of attack techniques. The main challenge lies in the vulnerabilities of traditional authentication solutions, which do not adequately ensure the integrity and authenticity of transactions. Conventional methods, such as TANs and security tokens, fail to guarantee that transaction content remains intact, especially on untrusted terminals. In addition, many systems rely too heavily on user knowledge, such as passwords and PINs, making them susceptible to phishing and social engineering attacks. Introduces the Dynamic Authorization Protocol (DAP), which utilizes two-factor visual authentication through QR codes. This approach allows users to authenticate transactions directly on their mobile devices, significantly enhancing the security of the process. The system implements a challenge-response authentication mechanism, where users receive a visual code that must be validated on their mobile devices, thus confirming the authenticity of the transaction. A key feature of the proposal is that it does not require direct communication between the mobile device and banking servers, using only the visual code to establish authenticity, which reduces the risk of attacks.

The protocol is designed to be compatible and user-friendly, enabling it to be implemented on common devices without the need for specific hardware or software. This facilitates its adoption by various financial institutions. The proposal seeks to mitigate the risks of fraud and attacks, thus increasing user confidence in online banking transactions. A

prototype was developed and efficiency was demonstrated in real-world scenarios, resulting in a system that ensures the integrity, authenticity, and confidentiality of transactions.

In summary, the DAP is a robust and innovative solution, adapted to the ever-evolving security landscape of digital financial transactions, while addressing the shortcomings of traditional authentication approaches. The effectiveness of identifying and addressing vulnerabilities in Internet banking systems is crucial to ensuring transaction security and maintaining user trust. Attacks often result from the exploitation of fragile elements characterized by identifiable weaknesses. It is important to recognize that these vulnerabilities may have different origins, such as software flaws, procedural gaps, or inadequate security practices. Although some weaknesses may arise from collaborative efforts among malicious actors, others may exist independently, arising from inherent system fragilities.

A significant challenge in understanding and mitigating these attacks is the lack of standardization in defining attack types and their respective impact levels. Each scenario may expose different vulnerabilities, which require a tailored approach to threat assessment. As the cyber threat landscape evolves, so too must the criteria for evaluating potential risks and the methodologies to address them. This continuous adaptation is essential to ensure that financial institutions can respond effectively to the dynamic nature of security threats.

To illustrate these complexities, it is relevant to consider different attack vectors and their implications for the robustness of online banking systems. Each type of attack not only exploits specific vulnerabilities, but also triggers cascading effects that can compromise the integrity and confidentiality of user transactions. Therefore, a comprehensive analysis must encompass both the immediate repercussions of an attack and the long-term trust issues that may arise from such incidents.

The interconnected nature of these vulnerabilities underscores the importance of an integrated security approach. Financial institutions must prioritize a multilayered security strategy that includes technological safeguards, user education, and effective response protocols to handle potential breaches. The human factor remains a central challenge, as users may inadvertently introduce vulnerabilities into otherwise secure systems due to actions influenced by social engineering tactics or lack of security awareness.

In conclusion, this analysis of the results reinforces the importance of continuous evaluation and enhancement of security measures to protect Internet banking systems. Understanding the scope of vulnerabilities and the motivations behind attacks enables financial institutions to implement robust defenses that not only address known issues, but also anticipate future challenges in the ever-changing cyber threat landscape. An adaptive and proactive stance in security management will be crucial in maintaining user confidence and ensuring the integrity of digital transactions in the face of persistent threats.

## 7. Conclusions

Throughout the development of our study, we gained a deep understanding of the evolution of security in online banking transactions and the implementation of a new authentication protocol. Initially, we established the necessary foundations to understand the challenges that internet banking faces, particularly in relation to cybersecurity. The increasing incidence of fraud and cyberattacks underscores the importance of a robust system that not only protects user credentials but also provides an efficient means of authentication and authorization. Furthermore, we examined the practical application of the visual two-factor authorization protocol that we proposed. This innovative approach not only addresses the initial concerns but also effectively adapts to the needs of modern users. By allowing users to authenticate their transactions using mobile devices and visual codes, we ensure an additional layer of security that is essential in a constantly evolving digital landscape. The interaction between the user's computer and the mobile device, without the need for direct online communication, marks a significant advancement in protection against man-in-the-middle and phishing attacks. Thus, upon reflecting on the topics discussed, it becomes clear that the integration of modern technologies and security protocols can transform the way we conduct banking transactions. The presented protocol

stands out not only for its effectiveness and practicality but also for its ability to adapt to existing systems, offering a viable solution for financial institutions seeking to strengthen their security. Ultimately, this work reaffirms the importance of continuous innovation in the field of cybersecurity, ensuring that access to Internet banking is not only convenient, but also secure.

Internet banking systems are essential tools for modern life, providing easy access and more efficient integration between financial institutions and their clients. This proposal was implemented in 2012, and currently we have over 3.6 million users. Channel segmentation, where a transaction is executed in one channel and authorized in another, is quite widespread. However, we must consider 12 years of testing this protocol without any recorded vulnerabilities, except for the human factor, which makes it a very robust solution that is still in use today.

The main challenges are associated with secure development and the human factor, when the legitimate user is convinced to operate the system under the adversary's guidance, which can vary for each context. The new out-of-band protocol, called DAP (Dynamic Authorization Protocol), brings several significant contributions to security in Internet Banking systems. First, it seeks to solve known security-related issues, ensuring the integrity, authenticity, and confidentiality of banking transactions. Through an approach that combines strong cryptography and communication protocols, DAP is designed to be practical, requiring low computational power and minimal user interaction, facilitating its implementation in real environments.

One of the innovations offered by the protocol is out-of-band authentication, which is widely recommended by regulatory bodies of the financial system. This allows users to authenticate a specific and unique transaction through an out-of-band channel without requiring connectivity, presenting a genuine second-factor authentication solution. This approach also reduces vulnerability to attacks such as social engineering, as the key used for authentication is securely stored and cannot be accidentally typed or disclosed by the user.

In addition to security features, DAP is designed not to rely on specific hardware or software, allowing users to access their information from different operating systems and devices, increasing the accessibility of the solution. The ability to operate on mobile devices is a crucial differentiator, as applications developed for these systems have fewer permissions to access information from other applications, adding an extra layer of security. Thus, the DAP protocol represents a significant contribution to the field of digital transaction security and secure authentication methods.

#### *Future Works*

The protocol was designed to be used in offline mode, not only to reduce exposure to attacks but also to avoid restricting its use when network instability occurs. However, this approach may make less sense now, and an online proposal might be a more expected response, as a transaction that starts in one channel and ends in another can be entirely online, making the process even more agile. Still, caution and analysis of new emerging threats that may impact the protocol's security are necessary.

The DAP proposal was intended for the authentication of banking transactions, but the same process can be extended to other forms of authentication, such as purchases on card machines, card readers, credit card terminals, payment terminals, point-of-sale (POS) terminals, or card payment devices, and even static payments such as offers in physical magazines, books, and even restaurant menus. In this sense, an application of DAP for these payment methods would be promising.

The model adopted in the tests and the real implementation was the symmetric model. In this work, we proposed an asymmetric model that has not been implemented, and we strongly suggest that it be tested in a real-use environment, not limited to a banking financial context. It could be expanded to other types of authorization such as network

access logins, password vaults for critical users, protection of highly sensitive information and credentials, among other applications.

## 8. Patents

Patent Registry Brazil INPI PI 1101459-8 A2 date 4 January 2011 publication on 05/03/2016.

**Author Contributions:** Conceptualization, L.P.d.M., D.M.A., R.d.O.A., R.T.d.S.J., A.L.S.O. and L.J.G.V.; methodology, L.P.d.M., D.M.A., R.d.O.A., R.T.d.S.J., A.L.S.O. and L.J.G.V.; validation, L.P.d.M., D.M.A., R.d.O.A., R.T.d.S.J., A.L.S.O. and L.J.G.V.; formal analysis, L.P.d.M., D.M.A., R.d.O.A., R.T.d.S.J., A.L.S.O. and L.J.G.V.; investigation, L.P.d.M., D.M.A., R.d.O.A., R.T.d.S.J., A.L.S.O. and L.J.G.V.; writing—original draft preparation, L.P.d.M., D.M.A., R.d.O.A., R.T.d.S.J., A.L.S.O. and L.J.G.V.; writing—review and editing, L.P.d.M., D.M.A., R.d.O.A., R.T.d.S.J., A.L.S.O. and L.J.G.V.; visualization, L.P.d.M., D.M.A., R.d.O.A., R.T.d.S.J., A.L.S.O. and L.J.G.V. All authors have read and agreed to the published version of the manuscript.

**Funding:** This work was supported by funds from the Recovery, Transformation and Resilience Plan, financed by the European Union (Next Generation), through the INCIBE-UCM. “Cybersecurity for Innovation and Digital Protection” Chair. The content of this article does not reflect the official opinion of the European Union. Responsibility for the information and views expressed therein lies entirely with the authors.

**Data Availability Statement:** The datasets presented in this article are not readily available. Requests to access the datasets should be directed to corresponding author.

**Acknowledgments:** The authors would like to thank Bank of Brazil for supporting this research and for participating in the implementation of the model proposed here for all the institution’s customers. Also we would like to thank the Laboratory of Technologies for Decision Making—LATITUDE, University of Brasilia.

**Conflicts of Interest:** The authors declare no conflicts of interest.

## References

1. de Oliveira Albuquerque, R.; Cohen, F.F.; Mota, J.L.T.; de Sousa Júnior, R.T. Analysis of a Trust and Reputation Model Applied to a Computational Grid Using Software Agents. In Proceedings of the 2008 International Conference on Convergence and Hybrid Information Technology, Daejeon, Republic of Korea, 28–29 August 2008; pp. 196–203. [\[CrossRef\]](#)
2. Peotta, L.; Holtz, M.D.; David, B.M.; Deus, F.G. A Formal Classification of Internet Banking Attacks And Vulnerabilities. *J. Comput. Sci. Inf. Technol. (IJCSIT)* **2011**, *3*, 186–197. [\[CrossRef\]](#)
3. Ghelani, D.; Hua, T.K.; Kumar, S.; Koduru, R.; Hua, T.K. Cyber Security Threats, Vulnerabilities, and Security Solutions Models in Banking. *Am. J. Comput. Sci. Technol.* **2022**. [\[CrossRef\]](#)
4. Gates, K.A. *Our Biometric Future: Facial Recognition Technology and the Culture of Surveillance*; New York University Press: New York, NY, USA, 2011. [\[CrossRef\]](#)
5. Nelson, L. Proposed Method for Evaluating Voice Authentication Systems. Master’s Thesis, University of Wisconsin-Madison, Madison, WI, USA, 2012.
6. Paulson, L.C. The inductive approach to verifying cryptographic protocols. *J. Comput. Secur.* **1998**, *6*, 85–128. [\[CrossRef\]](#)
7. de Oliveira, F.R. Verification of the Dynamic Authorization Protocol. Master’s Thesis, Brasília University, Brasília, Brazil, 2019.
8. Khan, H.U.; Sohail, M.; Nazir, S.; Hussain, T.; Shah, B.; Ali, F. Role of authentication factors in Fin-tech mobile transaction security. *J. Big Data Springer* **2023**, *10*, 138. [\[CrossRef\]](#)
9. Ajish, S.; Anil Kumar, K.S. Secure Mobile Internet Banking System Using QR Code and Biometric Authentication. In Proceedings of the Computer Networks, Big Data and IoT, Tiruchirappalli, India, 9–10 December 2022; Pandian, A.P., Fernando, X., Haoxiang, W., Eds.; Springer: Berlin/Heidelberg, Germany, 2022; pp. 791–807.
10. Sonawane, S.; Khandave, M.; Nemade, N. Secure Authentication for Online Banking Using QR Code. In Proceedings of the International Conference on Computer Networks, Big Data and IoT, Tiruchirappalli, India, 9–10 December 2022; pp. 791–807.
11. Lyu, L.; Tang, Q. Secure Mobile Authentication Using QR Codes for Banking Systems. *Int. J. Inf. Secur.* **2021**. [\[CrossRef\]](#)
12. Starnberger, G.; Frohofer, L.; Goeschka, K.M. QR-TAN: Secure mobile transaction authentication. In Proceedings of the Proceedings—International Conference on Availability, Reliability and Security, ARES 2009, Fukuoka, Japan, 16–19 March 2009; pp. 578–583. [\[CrossRef\]](#)
13. Jover, R.P. Security Analysis of SMS as a Second Factor of Authentication: The challenges of multifactor authentication based on SMS, including cellular security deficiencies, SS7 exploits, and SIM swapping. *Queue* **2020**, *18*, 37–60. [\[CrossRef\]](#)

14. Reese, K.; Smith, T.; Dutson, J.; Armknecht, J.; Cameron, J.; Seamons, K. A Usability Study of Five Two-Factor Authentication Methods. In Proceedings of the Fifteenth Symposium on Usable Privacy and Security (SOUPS 2019), Santa Clara, CA, USA, 12–13 August 2019; pp. 357–370.
15. Salameh, N.; Khashan, O.; Kanaker, H.; Abdulraheem, W.; Al Shinwan, M.; Albanna, A. Online Banking User Authentication Methods: A Systematic Literature Review. *IEEE Access* **2023**, *12*, 741–757. [\[CrossRef\]](#)
16. El Amin, H.; Samhat, A.E.; Chamoun, M.; Oueidat, L.; Feghali, A. An Integrated Approach to Cyber Risk Management with Cyber Threat Intelligence Framework to Secure Critical Infrastructure. *J. Cybersecur. Priv.* **2024**, *4*, 357–381. [\[CrossRef\]](#)
17. Gao, Q.; Fan, H.; Yu, C. Systemic Importance and Risk Characteristics of Banks Based on a Multi-Layer Financial Network Analysis. *Entropy* **2024**, *26*, 378. [\[CrossRef\]](#)
18. Ravilla, H.; Sayal, R.; Kulkarni, P. Study and Analysis of FIDO2 Passwordless Web Authentication. In *Advances in Computational Intelligence and Informatics*; Springer: Berlin/Heidelberg, Germany, 2024; pp. 991–997. [\[CrossRef\]](#)
19. Shafique, U.; Khan, H.; ud-din Waqar, S.; Sher, A.; Zeb, A.; Shafi, U.; Ullah, R.; Ullah, R. Modern Authentication Techniques in Smart Phones: Security and Usability Perspective. *Int. J. Adv. Comput. Sci. Appl.* **2017**, *8*, 331–340. [\[CrossRef\]](#)
20. Byers, D.; Shahmehri, N. Unified modeling of attacks, vulnerabilities and security activities. In Proceedings of the 2010 ICSE Workshop on Software Engineering for Secure Systems, New York, NY, USA, 5 February 2010; SESS '10, pp. 36–42. [\[CrossRef\]](#)
21. Shannon, C.E. The mathematical theory of communication. *Bell Syst. Tech. J.* **1948**, *27*, 379–423. [\[CrossRef\]](#)
22. Li, N. Efficient Equality Test on Identity-Based Ciphertexts Supporting Flexible Authorization. *Entropy* **2023**, *25*, 362. [\[CrossRef\]](#) [\[PubMed\]](#)
23. Rodopoulos de Oliveira, F. Repository DAP Verification. 2024. Available online: <https://github.com/rodopoulos/dap-verification> (accessed on 30 July 2024).
24. Rivest, R.L.; Shamir, A.; Adleman, L. A method for obtaining digital signatures and public-key cryptosystems. *Commun. ACM* **1978**, *21*, 120–126. [\[CrossRef\]](#)
25. Diffie, W.; Oorschot, P.C.V.; Wiener, M.J. Authentication and Authenticated Key Exchanges. *Des. Codes Cryptogr.* **1992**, *2*, 107–125. [\[CrossRef\]](#)
26. Katz, J.; Lindell, Y. *Introduction to Modern Cryptography*, 2nd ed.; Chapman and Hall/CRC: Boca Raton, FL, USA, 2014.
27. Kiljan, S.; Vranken, H.; van Eekelen, M. Evaluation of transaction authentication methods for online banking. *Future Gener. Comput. Syst.* **2018**, *80*, 430–447. [\[CrossRef\]](#)
28. Company, G.N. Payment Authentication in 2019—Trends and Predictions: Common Authentication Methods to Protect Online Payment. 2019. Available online: <https://www.gpayments.com/resources/whitepapers/online-payment-authentication-in-2019-trends-and-predictions/> (access on 31 October 2024).
29. Yildirim, N.; Varol, A. A Research on Security Vulnerabilities in Online and Mobile Banking Systems. In Proceedings of the 2019 7th International Symposium on Digital Forensics and Security (ISDFS), Barcelos, Portugal, 10–12 June 2019; pp. 1–5. [\[CrossRef\]](#)
30. Hasan, M.F.; Al-Ramadan, N.S. Cyber-attacks and Cyber Security Readiness: Iraqi Private Banks Case. *Soc. Sci. Humanit. J. (SSHJ)* **2021**, *5*, 2312–2323. [\[CrossRef\]](#)
31. Balhasan, A.B.; Alkasi, I.A.; Sallabi, W.S.; Bokhatwa, M.B.; Bilhasan, A.S.; Alhuni, S.A. A Case Study on the Information Security System of Al Wahda Bank. In Proceedings of the 2022 International Conference on Electrical and Computing Technologies and Applications (ICECTA), Ras Al Khaimah, United Arab Emirates, 23–25 November 2022; pp. 196–200. [\[CrossRef\]](#)
32. Almomani, A.; Gupta, B.S.; Atawneh, S.; Meulenberg, A.; Al-Zobi, M. Phishing Attacks: A Recent Comprehensive Study and a New Anatomy. In Proceedings of the 6th International Conference on Information Technology, Bangkok, Thailand, 12–13 December 2013; pp. 1–6. [\[CrossRef\]](#)
33. Iosif, M.; Tzovaras, D.; Tsolakis, N.; Kostaridis, I. A systematic review and research challenges on phishing cyberattacks from an electroencephalography and gaze-based perspective. *Pers. Ubiquitous Comput.* **2023**, *28*, 449–470. [\[CrossRef\]](#)
34. Syed, A.M. Social engineering: Concepts, Techniques and Security Countermeasures. *arXiv* **2021**, arXiv:2107.14082. [\[CrossRef\]](#)
35. Adham, M.; Azodi, A.; Desmedt, Y.; Karaolis, I. How to Attack Two-Factor Authentication Internet Banking. In Proceedings of the Financial Cryptography and Data Security, Okinawa, Japan, 1–5 April 2013; Sadeghi, A.R., Ed.; Springer: Berlin/Heidelberg, Germany, 2013; pp. 322–328. [\[CrossRef\]](#)
36. Anderson, R.; Bond, M. The Man-in-the-Middle Defence. In *International Workshop on Security Protocols*; Christianson, B., Crispo, B., Malcolm, J.A., Roe, M., Eds.; Springer: Berlin/Heidelberg, Germany, 2009; pp. 153–156. [\[CrossRef\]](#)
37. Choudary, O.S. The Smart Card Detective: A Hand-Held EMV Interceptor. Master's Thesis, University of Cambridge, Cambridge, UK, 2010.
38. Shoup, V.; Rubin, A. Session key distribution using smart cards. In Proceedings of the 15th Annual International Conference on Theory and Application of Cryptographic Techniques, Saragossa, Spain, 12–16 May 1996; Springer: Berlin/Heidelberg, Germany, 1996; EUROCRYPT'96, pp. 321–331. [\[CrossRef\]](#)
39. Li, Y.; Liu, Q. A comprehensive review study of cyber-attacks and cyber security; Emerging trends and recent developments. *Energy Rep.* **2021**, *7*, 8176–8186. [\[CrossRef\]](#)
40. Hattali, S.; Hussain, S.; Frank, A. Design and development for detection and prevention of ATM skimming frauds. *Indones. J. Electr. Eng. Comput. Sci.* **2020**, *17*, 1224. [\[CrossRef\]](#)
41. Ahmed, K.; Qaisar, S.; Din, I.U.; Rehman, M.U. Detection of Man-in-the-Middle Attacks using Machine Learning. In Proceedings of the 2020 IEEE ICMLA, Virtual, 14–17 December 2020. [\[CrossRef\]](#)

42. Karia, A.M.A.R.; Patankar, M.T. Analyzing the Security of OTP 2FA in the Face of Malicious Terminals. In Proceedings of the International Conference on Recent Trends in Advanced Computing, Chennai, India, 11–12 November 2020; pp. 314–329. [\[CrossRef\]](#)
43. Bellare, M.; Rogaway, P. Entity authentication and key distribution. In Proceedings of the 13th Annual International Cryptology Conference on Advances in Cryptology, Santa Barbara, CA, USA, 22–26 August 1994; Springer: Berlin/Heidelberg, Germany, 1994; CRYPTO '93, pp. 232–249. [\[CrossRef\]](#)
44. Fernandez, E.B.; Uzunov, A.V. Abstract Security Patterns and the Design of Secure Systems. *Cybersecurity* **2024**, *7*, 12–25. [\[CrossRef\]](#)
45. Peotta, L.; Gondim, P. *Risk Assessment and Real Time Vulnerability Identification in IT Environments*; IGI Global: Hershey, PA, USA, 2012; pp. 229–253. [\[CrossRef\]](#)
46. de Melo, L.P. DAP (Dynamic Authorization Protocol): Secure Approach Out-of-Band for E-Bank with a Two Factor Visual Authentication. Ph.D. Thesis, University of Brasilia, Brasília, Brazil, 2012.

**Disclaimer/Publisher's Note:** The statements, opinions and data contained in all publications are solely those of the individual author(s) and contributor(s) and not of MDPI and/or the editor(s). MDPI and/or the editor(s) disclaim responsibility for any injury to people or property resulting from any ideas, methods, instructions or products referred to in the content.